Guía P3 — Terceros, IA, hallazgos y plan

Nov 3, 2026 · @Anthony

Lo que te toca

Te toca lo que dependía de terceros y lo que viene después del ataque: evaluar al Proveedor, el SLA, el SOC 2, el marco legal, la privacidad y el chatbot, y cerrar el proyecto con los hallazgos, el plan a 90 días y el presupuesto. En el equipo eres la revisión de calidad: consolidas los hallazgos de los tres y revisas el informe integrado antes de entregarlo.

Tu parte pesa en terceros, privacidad y cumplimiento (1.5), calidad de hallazgos (1.5) y prevención, IA y seguimiento (1.5). Compartes con P1 contención, recuperación y continuidad (1.5): él evalúa lo que se hizo esa noche y tú la continuidad y el plan.

En concreto: BIA de referencia, ficha del Proveedor, responsabilidad compartida y SOC 2, comparación del SLA con la caída real, marco legal verificado, evaluación de privacidad, pruebas del chatbot en laboratorio, consolidación de hallazgos, plan de acción con indicadores, reparto de los Q350,000 y resumen ejecutivo.

Cómo nos repartimos el proyecto

El proyecto se parte en tres frentes que siguen las fases del caso: antes, durante y después del ataque. Cada frente tiene un dueño, pero los hallazgos y la defensa son de los tres.

	P1 · Durante	P2 · Antes	P3 · Después
Tema	Incidente, evidencia y simulación	Planeación, riesgos y controles	Terceros, IA, hallazgos y plan
Papel en el equipo	Analista técnico y custodio de evidencias	Coordinación e integración del informe	Revisión de calidad y cierre
Misiones del caso	C: forense, SQL Server, cronología, causa raíz	A, B y la parte de C sobre accesos, cambios, aplicaciones y móvil	D y E: terceros, privacidad, IA, hallazgos, plan y presupuesto

	P1 · Durante	P2 · Antes	P3 · Después
Alertas que prueba	08	01, 02, 03, 04, 09	05, 06, 07, 10, 11, 12
Evidencias que documenta	E-02, E-03, E-04, E-05, E-07	E-01, E-06	E-08, E-09, E-10
Contradicciones que resuelve	Administrador de BD, Seguridad Informática	Desarrollo	Gerencia de TI, Proveedor cloud, Comité de Auditoría, Continuidad
Preguntas del comité	01, 02, 03, 06, 07	09, 10	04, 05, 08
Carpetas a su cargo	03_Evidencias, 04_SQL y la presentación	01_Informe, 02_Matrices, 07_Referencias	05_Plan y el resumen ejecutivo
Rúbrica que más depende de su parte	Forense 2.5; comparte Controles de BD y Contención	Planeación 1.0, Riesgos 2.0, Controles 2.0	Terceros 1.5, Hallazgos 1.5, IA y seguimiento 1.5; comparte Contención

Los tres escriben su parte del informe, dos borradores de hallazgos y su propio registro de uso de IA. La defensa (1.5 puntos) es de todos, y cada uno responde por su frente.

Tus entregables

Entregas ocho productos propios, consolidas los hallazgos de los tres y haces la revisión de calidad del informe integrado.

Entregable	Dónde queda	Qué lleva
BIA de referencia (S-05)	05_Plan/BIA_referencia.xlsx y sección 7 del informe	RTO, RPO y tiempo máximo tolerable por proceso, con su justificación

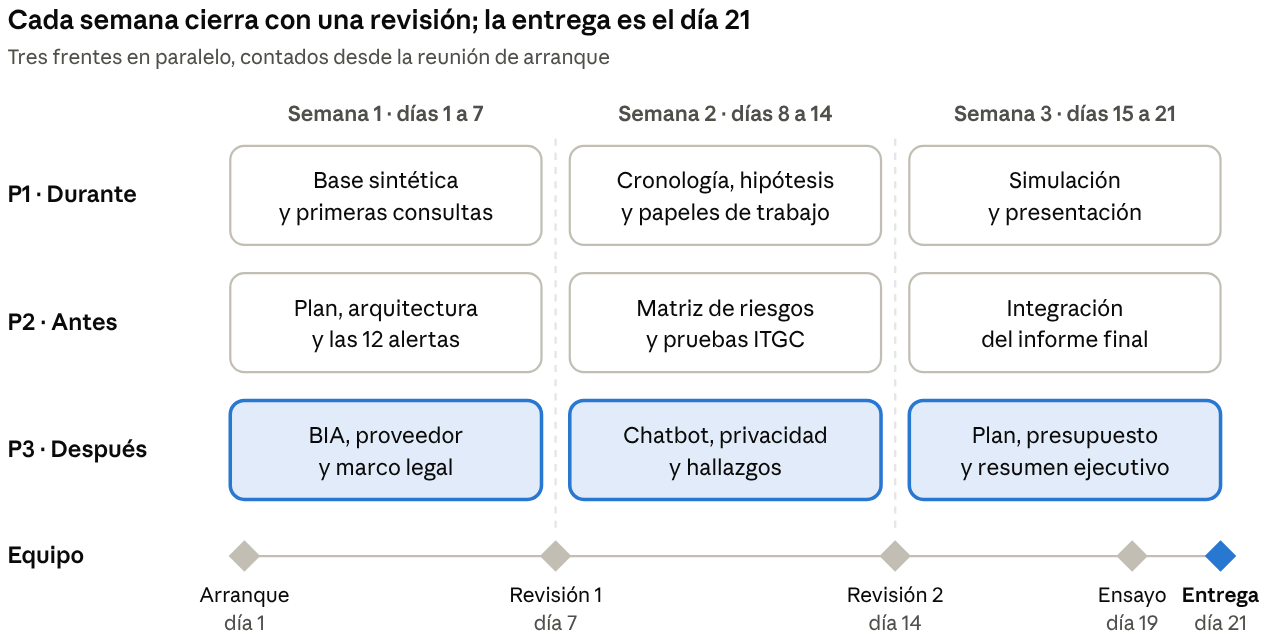
Entregable	Dónde queda	Qué lleva
Ficha del Proveedor y responsabilidad compartida	Sección 8 y anexo	Servicios, subcontratistas, alcance del SOC 2, cláusulas, accesos, plan de salida y quién responde por qué
SLA frente a la caída real	Secciones 7 y 8	Cálculo de disponibilidad con y sin exclusiones, comparado con el BIA
Marco legal y contractual	Sección 8	Normas que aplican y que no, con artículo, vigencia y fuente oficial
Privacidad y chatbot	Sección 8 y anexo	Clasificación propuesta, evaluación de privacidad, casos de prueba IA-01 en adelante y ficha de riesgos de IA
Papeles de trabajo PT-40 en adelante	Se los pasas a P1	E-08, E-09, E-10 y tus demás pruebas
Hallazgos consolidados	Sección 9	Cinco o más hallazgos completos, priorizados y con código final H-xx
Plan de acción y presupuesto	05_Plan/Plan_Accion.xlsx y sección 10	Acciones por horizonte, Q350,000, indicadores, verificación a 30 y 90 días y riesgos aceptados

Entregable	Dónde queda	Qué lleva
Resumen ejecutivo	06_Comite/Resumen_y_Presentacion.pdf	Una página para el comité, impresa el día de la defensa

En la presentación te tocan cinco diapositivas: Proveedor y SLA, chatbot, hallazgos, plan y presupuesto, y decisiones para el comité. Además narras la corrida 2 de la simulación.

Tu plan semana por semana

Contamos tres semanas desde la reunión de arranque (día 1) hasta la entrega (día 21). Si la fecha real cae antes, se comprimen las semanas, pero el BIA tiene que estar el día 4 y el plan el día 16, porque de ellos dependen los demás.



plan del equipo · tu carril resaltado

Tu carril va resaltado. Tu semana 3 depende de lo que te llega los días 11, 12 y 15; si algo se atrasa, el plan se aprieta.

Semana 1 · días 1 a 7: BIA, Proveedor y marco legal

- [ ] Día 1: reunión de arranque; proponer S-01 (proveedor principal y subcontratistas).
- [ ] Días 1 a 4: BIA de referencia (S-05), para todos el día 4.

- [ ] Días 2 a 6: ficha del Proveedor, contrato sintético con cláusulas ficticias (SLA, notificación, auditoría, subcontratación) y análisis del SOC 2.
- [ ] Días 3 a 7: marco legal, verificando cada norma en fuente oficial, incluido el estado del Decreto 26-2026.
- [ ] Día 6: recibir de P1 el resultado de Q-09 y el supuesto S-04.
- [ ] Día 7: revisión 1.

Semana 2 · días 8 a 14: chatbot, privacidad y hallazgos

- [ ] Día 8: tus pruebas T-40 en adelante a P2 y el supuesto S-08 (puntaje del chatbot).
- [ ] Armar el laboratorio del chatbot con datos ficticios y correr los casos IA-01 en adelante.
- [ ] Evaluación de privacidad y propuesta de clasificación de datos (alerta 06).
- [ ] Día 11: recibir de P1 la cronología normalizada; calcular el SLA contra la caída real y el BIA.
- [ ] Papeles PT-40 en adelante (E-08, E-09, E-10).
- [ ] Día 12: recibir los borradores de P1 y P2, y pasarle los tuyos a P2 para que los revise.
- [ ] Día 14: revisión 2; revisar los de P1 como si fueras el auditado.

Semana 3 · días 15 a 21: hallazgos, plan y cierre

- [ ] Día 15: lista consolidada de hallazgos con su código final H-xx; recibir de P1 las acciones de 0–24 h y 24–72 h.
- [ ] Días 15 y 16: plan de acción con indicadores y presupuesto de Q350,000.
- [ ] Día 16: plan y acciones para la corrida 2, a P1 y P2.
- [ ] Día 17: tu sección del informe y tu registro de IA a P2; tus diapositivas a P1.
- [ ] Día 18: revisión de calidad del informe integrado y resumen ejecutivo.
- [ ] Día 19: ensayo general.
- [ ] Día 20: correcciones e impresión del resumen ejecutivo para el comité.
- [ ] Día 21: entrega.

Lo que recibes y lo que entregas

Tú cierras lo que los otros abren: recibes más de lo que entregas, así que conviene recordarles las fechas de los días 11, 12 y 15.

Lo que entregas

Día	Qué	Para
1	Supuesto S-01 propuesto	Todos
4	BIA de referencia (S-05)	P1 y P2
8	Tus pruebas T-40 en adelante y el supuesto S-08	P2
12	Tus borradores B3-1 y B3-2	P2
14	Objeciones a los borradores de P1	P1
15	Lista consolidada de hallazgos con código final	Todos
16	Plan de acción, presupuesto y acciones para la corrida 2	P1 y P2
17	Tu sección del informe, fuentes y registro de uso de IA	P2
17	Tus diapositivas y papeles PT-40 en adelante	P1
19	Correcciones de la revisión de calidad	P2
20	Resumen ejecutivo final	P1, para 06_Comite

Lo que recibes

Día	Qué	De
4	Escala de riesgo y tabla de las 12 alertas en borrador	P2
6	Resultado de Q-09 y supuesto S-04	P1
10	Matriz de riesgos v1 y Top 5	P2
11	Cronología normalizada y tiempos de caída y recuperación	P1
12	Borradores B1-1, B1-2, B2-1 y B2-2	P1 y P2
14	Objeciones de P2 a tus borradores	P2
15	Acciones de 0–24 h y 24–72 h de la evaluación de la respuesta	P1

Día	Qué	De
18	Informe integrado, para revisión de calidad	P2

Cómo cerrar los hallazgos, el plan y el presupuesto

Tu trabajo final es que la cadena del curso no se rompa: cada hallazgo tiene al menos una acción, cada acción un indicador, y cada indicador una forma de verificarlo a 30 y 90 días.

1. Día 12: recibes seis borradores, dos por persona, con la plantilla D.
2. Buscas causas repetidas. Si dos borradores tienen la misma causa raíz, se fusionan en un solo hallazgo con varias condiciones.
3. Priorizas con el puntaje residual de la matriz de P2 y la urgencia, y numeras de H-01 en adelante. Lo que no alcanzó evidencia va aparte, como "asuntos no concluyentes".
4. Día 14: con las objeciones de la revisión cruzada, cada dueño ajusta su borrador o lo defiende.
5. Días 15 y 16: cada hallazgo pasa al plan con al menos una acción (A-xx), su indicador (K-xx), su evidencia de cierre y quién lo verifica.
6. El presupuesto de Q350,000 se reparte por prioridad. Lo que no se financia queda escrito, junto con quién acepta ese riesgo.
7. La verificación a 30 y 90 días usa las mismas consultas de P1: si Q-02 encontraba cuentas privilegiadas sin MFA, la prueba de cierre es que Q-02 ya no encuentre ninguna.

Un consejo práctico: arma el plan en la hoja de cálculo primero y escribe la sección del informe al final. Así las cifras del texto salen de la hoja y no al revés.

La defensa de 12 minutos

Tú cierras la defensa: después de la forense de P1 muestras qué se propone, cuánto cuesta y qué decisiones le pides al comité. La dirige P1, que arma la estructura de diapositivas y lleva el cronómetro.

Minuto	Quién	Qué se muestra
0:00 a 2:00	P1	Corrida 1: la noche del 14 según los registros

Minuto	Quién	Qué se muestra
2:00 a 5:30	P2	Encargo, alcance y criterios; de las 12 alertas a la matriz; Top 5; controles evaluados
5:30 a 8:00	P1	Cronología normalizada, hipótesis, qué está probado y qué no, causa raíz
8:00 a 11:00	P3	Proveedor, SLA y SOC 2; chatbot; hallazgos priorizados; plan y Q350,000
11:00 a 12:00	P3, con P1 operando	Corrida 2 con el plan funcionando; riesgo residual y decisiones que pedimos al comité

Tus diapositivas, unos 4 minutos en total

1. Proveedor, SLA y SOC 2: por qué el SLA pudo cumplirse y aun así fallarle al negocio, con el cálculo a la vista.
2. Chatbot: qué se probó en laboratorio y qué dice eso, y qué no, sobre RedNova.
3. Hallazgos priorizados: tabla corta con H-xx, título y prioridad.
4. Plan y presupuesto: los cuatro horizontes y en qué se van los Q350,000.
5. Decisiones para el comité: qué aprobar, qué aceptar y quién lo firma.

En la corrida 2 narras tú mientras P1 la opera: dónde se corta la cadena con cada acción del plan y qué riesgo queda. Lleva impreso el resumen ejecutivo, una copia por miembro del comité.

Convenciones del equipo

Se aprueban en la reunión de arranque y no se cambian sin avisar a los tres. Tú asignas los códigos finales de hallazgos, acciones e indicadores, así que esos números salen de ti.

Códigos

Qué	Código	Quién numera
Riesgos y controles	R-01…, C-01…	P2
Pruebas y papeles de trabajo	T-01 a T-19 y PT-01 a PT-19	P2
Pruebas y papeles de trabajo	T-20 a T-39 y PT-20 a PT-39	P1

Qué	Código	Quién numera
Pruebas y papeles de trabajo	T-40 a T-59 y PT-40 a PT-59	P3
Evidencias nuevas (E-01 a E-10 son del caso)	E-11 a E-29 / E-30 a E-39 / E-40 a E-49	P1 / P2 / P3; P1 lleva el índice de todas
Consultas SQL	Q-01 a Q-12	P1
Hallazgos	H-01… por prioridad; borradores B1-1, B2-1, B3-1…	P3
Acciones e indicadores del plan	A-01…, K-01…	P3
Supuestos del equipo	S-01…	P2 lleva el registro
Casos de prueba del chatbot	IA-01…	P3

Palabras con significado fijo

- Hecho confirmado: lo respalda evidencia suficiente y pertinente.
- Indicio: una señal que sugiere algo, pero no lo prueba.
- Hipótesis: una explicación posible, con evidencia a favor y en contra.
- Supuesto del equipo: algo que definimos porque el caso no lo dice; lleva código S-xx.
- No concluyente: lo disponible no alcanza para afirmar ni para descartar.

Nadie escribe "fuga" ni "exfiltración" como hecho mientras no esté probada. Se dice "transferencia de cerca de 1.6 GB hacia un destino externo no clasificado".

Supuestos que se aprueban al inicio

Código	Supuesto	Dueño	Listo el día
S-01	Nube, integraciones/API y soporte los presta un proveedor principal ("el Proveedor"), que usa subcontratistas	P3	1
S-02	Período revisado: controles del 1 de abril al 14 de octubre de 2026; incidente del 12 al 15 de octubre	P2	1
S-03	Hora de referencia: Guatemala (UTC−6), formato de 24 horas	P1	1

Código	Supuesto	Dueño	Listo el día
S-04	Horario de respaldos y fecha de la última restauración probada	P1	6
S-05	BIA de referencia: RTO, RPO y tiempo máximo tolerable por proceso	P3	4
S-06	Descriptores de probabilidad e impacto, escala de 1 a 5	P2	4
S-07	Tipo de cambio para costos en dólares, con la referencia del Banguat de una fecha fija	P3	15
S-08	Escala y umbral del puntaje de riesgo del chatbot (el 0.08 de E-10)	P3	8
S-09	Tamaño de la base sintética, por ejemplo 85,000 clientes ficticios	P1	3

Formato del informe

El de la plantilla UdeO que comparte P1: carta, márgenes de 1 pulgada, Times New Roman 12 justificado, interlineado 1.15, títulos de sección en 13 puntos negrita y tablas con el título "Tabla N." arriba. Citas y bibliografía en APA 7. Números con coma de miles y punto decimal: 31,840 registros, 1.6 GB, Q350,000.00.

Archivos

Una carpeta compartida con la estructura del curso, de 01_Informe a 07_Referencias. Nombres sin tildes ni espacios y con la versión al final, como Plan_Accion_v2.xlsx. Cada quien edita sus archivos; para tocar el de otro, se avisa antes.

Cómo usar tu documento para el agente de IA

El documento para el agente trae el caso resumido, las convenciones, las reglas y once tareas con lo que necesita para trabajar contigo. Úsalo así:

Tu documento para el agente: Agente IA P3 — Terceros, IA, hallazgos y plan

1. Abre una conversación nueva con el agente y pega el documento completo, o expórtalo a Markdown y adjúntalo. Adjunta también los dos PDFs del curso.
2. Pide una tarea a la vez ("Haz la Tarea 1") y revisa lo que entrega antes de pasar a la siguiente.

3. Trata lo que produzca como borrador. En tu frente esto pesa más que en ningún otro: las normas legales, los artículos y los precios se verifican en la fuente oficial, nunca se dan por buenos porque los dijo el agente.
4. Al cerrar cada sesión, pídele la entrada del registro de uso de IA. La validación y lo que aprendiste los completas tú, no el agente.
5. Si inventa algo (una ley, un artículo, una cifra), corrígelo y anótalo en el registro; eso también cuenta como validación.

Para las pruebas del chatbot vas a usar otro modelo de IA como laboratorio. Anota cuál fue, con qué versión y en qué fecha, porque eso también va en la declaración.

Lo que debes poder explicar sin leer

En la defensa preguntan a cada integrante por separado. Si puedes explicar cada punto con tus palabras y un dato del caso, estás listo.

1. Por qué un SLA puede cumplirse y aun así fallarle al negocio (pregunta 05), con el cálculo del 99.9 % en octubre y el RTO de tu BIA.
2. Qué cubre y qué no un informe SOC 2: tipo I o II, período, servicios en alcance, subcontratistas y los controles que le tocan a RedNova.
3. Quién responde por qué en la responsabilidad compartida, y por qué ni la Gerencia de TI ni el Proveedor tienen toda la razón sin el contrato y los registros.
4. La diferencia entre un respaldo exitoso y una restauración verificable (pregunta 04).
5. Qué normas de Guatemala aplican y cuáles no; qué cambia con el Decreto 26-2026 y por qué no se aplica en lo penal a hechos del 14 de octubre.
6. Cómo se probó el chatbot en laboratorio y por qué una salida de IA no es evidencia por sí sola (pregunta 08), usando el 0.08 de E-10 como ejemplo.
7. Cómo se consolidaron y priorizaron los hallazgos, y por qué ninguno repite causa raíz.
8. Por qué el presupuesto quedó repartido así, qué quedó sin financiar y quién acepta ese riesgo.
9. Cómo se va a verificar a 30 y 90 días que los controles siguen funcionando.
10. Cómo respondes a las cuatro contradicciones de tu frente: Gerencia de TI ("la culpa es del proveedor"), el Proveedor ("fue configuración del cliente"), el Comité de Auditoría ("el SOC 2 no cubre todo") y Continuidad ("la última restauración fue hace meses").

Revisión final antes de entregar

Marca cada punto el día 20. Como haces la revisión de calidad del equipo, los últimos dos puntos son sobre el informe de todos.

- [ ] Hay cinco o más hallazgos completos, sin causas repetidas y con su prioridad justificada.
- [ ] Cada acción del plan tiene hallazgo, prioridad, responsable, recursos, plazo, costo, indicador, evidencia de cierre, verificador y riesgo residual.
- [ ] El presupuesto suma Q350,000 o menos, o el exceso está justificado, y lo no financiado y los riesgos aceptados están escritos.
- [ ] Cada norma citada tiene artículo, vigencia y fuente oficial, y ninguna infracción se atribuye sin prueba.
- [ ] El análisis del SLA muestra el cálculo y los supuestos sobre qué cuenta como caída.
- [ ] Las pruebas del chatbot usaron solo datos ficticios y dicen qué demuestran sobre RedNova y qué no.
- [ ] El resumen ejecutivo cabe en una página.
- [ ] Revisaste en el informe integrado las citas, la ortografía, las sumas, los códigos y las fechas, y que los anexos coincidan con el texto.
- [ ] Tu registro de uso de IA ya está con P2.